

클라우드 보안 진단 리포트

1. 진단 요약

- 전체 점검 수: 9
- 양호 항목 수: 3
- 취약 항목 수: 6
- 보안 점수: 33
- 종합 의견: 현재 클라우드 환경은 9개 항목 중 6개 항목에서 보안 취약점이 발견되었습니다. 특히 IAM 계정 관리, 보안 그룹 설정, 로깅 설정 등에서 개선이 시급한 것으로 판단됩니다. 발견된 취약점들을 신속하게 조치하여 전반적인 보안 수준을 강화해야 합니다.

2. 우선 조치 대상

위험도와 영향도를 기준으로 우선 조치해야 할 항목을 정리합니다.

- IAM Admin User:** 최고 관리자 권한을 가진 계정이 서비스 운영 용도로 사용되는 것은 매우 위험합니다.
- IAM User MFA Enabled:** 일반 사용자 계정에 다중 인증(MFA)이 설정되어 있지 않아 계정 탈취 위험이 높습니다.
- Root Account MFA Enabled:** 가장 높은 권한을 가진 루트 계정에 다중 인증(MFA)이 설정되어 있지 않아 심각한 보안 위험이 될 수 있습니다.
- Security Group SSH Open:** SSH 포트가 전체 IP에 대해 열려 있어 외부로부터의 무단 접근 가능성이 있습니다.
- IAM Password Policy:** 비밀번호 정책이 설정되어 있지 않아 추측하기 쉬운 비밀번호 사용 및 보안 취약점을 야기할 수 있습니다.
- CloudTrail Enabled:** 사용자 활동에 대한 로그 기록이 없어 보안 사고 발생 시 원인 분석 및 추적이 어렵습니다.

3. 상세 취약점 분석

IAM Admin User

점검 항목

- 진단 항목: AdministratorAccess 권한 사용자
- 대상: IAM
- 위험도: 상
- KISA 코드: KISA-CLD-12
- SK윌더스 가이드 항목: 1.7

원인 분석

admin, test1, test2, test3 사용자는 AdministratorAccess 정책이 부여되어 모든 AWS 서비스에 접근할 수 있는 최고 관리자 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정이 일상적인 서비스 운영 용도로 사용될 경우, 의도치 않은 설정 변경이나 삭제, 악의적인 공격으로 인해 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 반드시 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM User MFA Enabled

점검 항목

- 진단 항목: MFA 미설정 사용자
- 대상: IAM
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK실더스 가이드 항목: 1.9

원인 분석

`admin`, `test1`, `test2`, `test3` 사용자에게 대해 다중 인증(MFA)이 설정되어 있지 않습니다.

보안 영향

MFA는 비밀번호 외에 추가적인 인증 수단을 요구하여 계정 탈취 위험을 크게 줄여줍니다. MFA가 설정되지 않은 계정은 비밀번호 유출 시 계정이 쉽게 탈취될 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정에도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

Root Account MFA Enabled

점검 항목

- 진단 항목: Root 계정에 MFA가 설정되어 있지 않습니다.
- 대상: IAM
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK윌더스 가이드 항목: 1.9

원인 분석

루트 계정에 다중 인증(MFA)이 설정되어 있지 않습니다.

보안 영향

루트 계정은 AWS 계정의 모든 권한을 가지고 있어 가장 중요합니다. MFA가 설정되어 있지 않으면 비밀번호 유출 시 계정이 탈취되어 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM Password Policy

점검 항목

- 진단 항목: 비밀번호 정책이 설정되어 있지 않거나 확인할 수 없습니다.
- 대상: IAM

- 위험도: 상
- KISA 코드: KISA-CLD-09
- SK실더스 가이드 항목: 1.10

원인 분석

IAM 계정의 비밀번호 정책이 설정되어 있지 않아, 비밀번호의 길이, 복잡성, 만료 주기 등에 대한 보안 기준이 적용되지 않고 있습니다.

보안 영향

비밀번호 정책이 없으면 사용자들이 추측하기 쉬운 비밀번호를 사용하거나, 비밀번호를 주기적으로 변경하지 않아 계정 탈취 위험이 높아집니다.

단계별 조치 가이드

1. IAM 콘솔에서 계정 설정 또는 암호 정책 메뉴로 이동합니다.
2. 최소 비밀번호 길이를 설정합니다.
3. 대문자, 소문자, 숫자, 특수문자 요구 조건을 설정합니다.
4. 비밀번호 만료 기간과 재사용 방지 정책을 설정합니다.
5. 변경된 정책이 IAM 사용자에게 적용되는지 확인합니다.

조치 후 확인 방법

1. IAM 비밀번호 정책이 활성화되어 있는지 확인합니다.
2. 복잡도와 만료 주기가 보안 기준에 맞는지 확인합니다.

근거 출처

- 문서: SK실더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.10 AWS 계정 패스워드 정책 관리

Security Group SSH Open

점검 항목

- 진단 항목: SSH가 전체 공개된 보안 그룹
- 대상: Security Group
- 위험도: 상

- KISA 코드: KISA-CLD-03
- SK윌더스 가이드 항목: 3.1

원인 분석

launch-wizard-2 (sg-0505ccf9abb1ac83e) 및 launch-wizard-3 (sg-0e45a1198d66249e4) 보안 그룹에서 SSH(포트 22)가 0.0.0.0/0 (전체 IP)으로 열려 있습니다.

보안 영향

SSH 포트가 모든 IP 주소에서 접근 가능하도록 설정되어 있어, 외부에서 무차별 대입 공격 (Brute-force attack)이나 악의적인 시도를 통해 서버에 접근할 위험이 있습니다.

단계별 조치 가이드

1. EC2 콘솔에서 보안 그룹 목록을 확인합니다.
2. 인바운드 및 아웃바운드 규칙을 검토합니다.
3. 0.0.0.0/0 또는 ::/0 으로 전체 포트가 허용된 규칙을 식별합니다.
4. 불필요한 ANY 허용 규칙을 삭제합니다.
5. 업무에 필요한 포트와 IP 대역만 허용합니다.

조치 후 확인 방법

1. 보안 그룹에 전체 포트 전체 대역 허용 규칙이 없는지 확인합니다.
2. SSH, RDP 등 관리 포트가 제한된 IP에서만 접근 가능한지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 3.1 보안 그룹 인/아웃바운드 ANY 설정 관리

CloudTrail Enabled

점검 항목

- 진단 항목: CloudTrail이 생성되어 있지 않습니다.
- 대상: CloudTrail
- 위험도: 상
- KISA 코드: KISA-CLD-08

- SK윌더스 가이드 항목: 4.7

원인 분석

AWS 계정의 활동을 기록하는 CloudTrail 서비스가 활성화되어 있지 않아, 사용자 계정의 활동 로그가 수집되지 않고 있습니다.

보안 영향

CloudTrail이 활성화되어 있지 않으면 보안 사고 발생 시 누가, 언제, 어떤 작업을 수행했는지 추적하기 어렵습니다. 이는 사고 원인 분석, 책임 규명, 재발 방지 대책 수립에 큰 어려움을 초래합니다.

단계별 조치 가이드

1. CloudTrail 콘솔로 이동합니다.
2. 새 추적을 생성하거나 기존 추적 설정을 확인합니다.
3. 관리 이벤트 로깅을 활성화합니다.
4. 로그 저장용 S3 버킷을 지정합니다.
5. 필요 시 CloudWatch Logs 연동을 설정합니다.

조치 후 확인 방법

1. CloudTrail 트레일이 존재하는지 확인합니다.
2. 최근 사용자 활동 이벤트가 기록되는지 확인합니다.
3. 로그 저장 대상 S3 버킷에 로그가 생성되는지 확인합니다.

근거 출처

- 문서: SK윌더스 2024 클라우드 보안 가이드 AWS
- 항목: 4.7 AWS 사용자 계정 로깅 설정

참고:

- S3 Public Access Block, S3 Bucket Encryption, RDS Public Access 항목은 현재 환경에 해당 리소스가 없어 양호 또는 해당 없음으로 판단되었습니다. 하지만 향후 리소스 생성 시에는 해당 보안 가이드에 따라 설정을 점검해야 합니다.